Scope-Bound Cybersecurity Evidence Passports With Independent Review and Living Assurance Lineage

Sri Sai Lakshmi Ganesh Murukutla

Murukutla Group LLC

Austin, Texas, United States

Author Note

ORCID: https://orcid.org/0009-0001-5057-7399

This research received no external funding. The author declares no conflict of interest related to the prototype evaluation reported in this manuscript.

OpenAI ChatGPT (OpenAI, 2026a) and Codex (OpenAI, 2026b) assisted with editorial restructuring, software development, generation of the reproducible evaluation harness, and document formatting in the abstract, main text, and appendix. The author reviewed and verified the resulting text, code, citations, experiments, and submission statements.

Correspondence concerning this article should be addressed to Sri Sai Lakshmi Ganesh Murukutla, Murukutla Group LLC, Austin, TX, USA. Contact: https://murukutlagroup.com/contact

Abstract

Cybersecurity decisions depend on reports, attestations, scan results, and provenance records whose meaning can be lost when they move between organizations. A digest detects byte changes but does not establish assessment scope, limitations, reviewer independence, currency, or supersession. This paper presents Sampling Sigma, a design science prototype for scope-bound cybersecurity evidence passports. The architecture keeps confidential evidence off-chain while binding a portable record to artifact integrity, subject, scope, limitations, validity, issuer, independent review, conflict disclosure, status, revocation, and lineage. A Solidity prototype, local verifier, and reproducible harness evaluate design-level behavior. Fifteen contract tests passed. A controlled corpus of 5,000 single-bit mutations produced 100% digest-mismatch detection, and an exhaustive 25-pair reference state-machine test rejected all 21 forbidden transitions. These measurements establish prototype consistency, not truth, security certification, interoperability, usability, or regulatory compliance. The paper contributes an explicit separation of integrity, provenance, validation, and economics, together with a preregisterable evaluation plan comparing raw digest exchange, signed centralized records, credential-only passports, and an optional shared registry.

Keywords: Blockchain, cybersecurity assurance, design science, evidence provenance, independent review, living assurance, privacy, smart contracts, verifiable credentials.

Scope-Bound Cybersecurity Evidence Passports With Independent Review and Living Assurance Lineage

Introduction

Cybersecurity evidence rarely fails only because its bytes change. It also fails when a relying party cannot determine what was assessed, what was excluded, who approved it, whether a conflict existed, or whether later evidence replaced it. Secure timestamping (Haber & Stornetta, 1991), supply-chain attestation (Torres-Arias et al., 2019), verifiable credentials (World Wide Web Consortium [W3C], 2025), and cybersecurity-control assessment (National Institute of Standards and Technology [NIST], 2022a) address important portions of this problem. They do not, by themselves, create a compact decision object that binds integrity to scope, limitations, independent review, validity, and supersession.

Sampling Sigma studies whether a portable cybersecurity evidence passport can preserve that decision context while confidential evidence remains under its owner's control. A shared ledger is treated as optional: it is retained only if comparative testing demonstrates cross-organization value that simpler signed records cannot provide.

The contributions are: 1) a minimum passport schema that records claims and claim boundaries; 2) separation of issuer, reviewer organization, relying party, and economic roles; 3) an append-only lifecycle with rejection, expiry, revocation, and supersession; and 4) a reproducible prototype evaluation plus a preregisterable field-study protocol.

Research Questions and Related Work

Research Questions

- RQ1: Which fields prevent a fingerprint from being mistaken for proof of truth or full-scope assurance?

- RQ2: Can organizational separation and conflict commitments make silent self-approval detectable?
- RQ3: Can explicit validity and lineage reduce acceptance of stale or superseded evidence?
- RQ4: Can local verification preserve confidentiality while remaining usable?
- RQ5: Under which multi-organization conditions does a shared registry add value over signed centralized records?

Research Gap

Haber and Stornetta (1991) established tamper-evident document timestamping. in-toto provides authenticated software-supply-chain provenance (Torres-Arias et al., 2019), while SLSA defines progressive artifact integrity practices (Supply-chain Levels for Software Artifacts [SLSA], n.d.). The W3C Verifiable Credentials Data Model supplies issuer, proof, status, and portable-claim semantics (World Wide Web Consortium [W3C], 2025). NIST SP 800-53A defines evidence-driven control assessment (National Institute of Standards and Technology [NIST], 2022a), and C2PA provides a related provenance and trust-model pattern (Coalition for Content Provenance and Authenticity [C2PA], n.d.). The unresolved systems gap is not the absence of hashes or ledgers. It is a compact, portable object that carries integrity together with sufficient context for a defensible cybersecurity assurance decision.

Design Science Method

The study follows the design science cycle described by Hevner et al. (2004): problem identification, requirements derivation, artifact construction, demonstration, evaluation, and communication. Requirements were derived from assessment, secure-development, provenance, credential, and threat-model guidance (W3C, 2025; NIST, 2022a; SLSA, n.d.; C2PA, n.d.; NIST,

2022b). Evaluation has three layers: deterministic contract tests; controlled mutation and reference state-machine experiments; and a planned comparative human study. Only the first two layers have measured results.

Table 1

Design Requirements and Protected Failure Modes

ID	Requirement	Failure
R1	Bind artifact, subject, scope, limitations, and period	Context collapse
R2	Separate issuer and reviewer organization	Self-approval
R3	Commit conflicts and review evidence	Hidden dependency
R4	Expose validity, rejection, revocation, supersession	Stale assurance
R5	Keep evidence off-chain; verify locally	Disclosure
R6	Separate validity from token economics	Economic capture

Architecture and Data Model

Assurance Planes

The architecture contains five assurance planes and one optional economic plane. The encrypted evidence vault retains source artifacts. The passport service canonicalizes, hashes, validates, and signs. The independence graph resolves organizations and disclosed relationships. The assurance registry records minimum commitments and lifecycle events. The local verifier recalculates the digest, validates signature and status, checks validity and supersession, and applies relying-party policy. The economic layer cannot determine evidence truth.

Table 2

Evidence Passport Field Groups

Group	Required fields
Identity	Schema version, passport ID, subject commitment
Integrity	Algorithm, artifact digest, canonicalization profile
Context	Domain, assessment type, scope and limitation commitments
Review	Issuer, reviewer organization, conflict and evidence commitments
Lifecycle	Issued time, valid-until, status, revocation, supersession
Proof	Signature suite, key identifier, policy and status endpoints

A successful digest check establishes byte equality with the committed artifact. It does not establish correctness, completeness, authorization, reviewer competence, or continuing security. This negative claim is part of the data model and verifier language, not a disclaimer added after deployment.

Formal Commitments and Decision Predicate

Let x be a JSON evidence passport excluding its proof. The portable commitment uses the JSON Canonicalization Scheme (Rundgren et al., 2020) followed by SHA-256 as specified by FIPS 180-4 (NIST, 2015).

$$C(x) = SHA\text{-}256(JCS(x)) \tag{1}$$

For passport P, artifact A, and decision time t, acceptance is conjunctive rather than score-based. Each indicator equals one only when its named check passes.

$$V = H \wedge S \wedge C \wedge R \wedge T \wedge Q \tag{2}$$

H recomputes the artifact commitment; S validates the issuer proof; C requires the relying party to acknowledge scope and limitations; R checks reviewer identity, organizational

separation, and conflict disclosure; T rejects expired, revoked, rejected, or superseded passports; and Q applies local policy. A zero in any term produces rejection. This model prevents confidence scores from overriding a failed mandatory control.

Threat Model

Table 3

Threats, Mitigations, and Residual Risks

Threat	Mitigation	Residual risk
Substitution	Local digest and signature check	Compromised endpoint
Scope inflation	Mandatory scope and limitations	Deceptive wording
Self-review	Role and organization separation	Collusion
Stale evidence	Expiry, revocation, supersession	Publication delay
Data leakage	Off-chain evidence and minimization	Metadata correlation
Admin compromise	Role separation, multisignature target, audit	Key compromise

Prototype Implementation

Smart Contract

The prototype uses Solidity 0.8.28 and OpenZeppelin components (OpenZeppelin, n.d.). SamplingSigmaAssuranceCore records subject, scope, limitations, validity, reviewer organization, conflict commitment, rejection, revocation, and supersession. A browser-local verifier hashes files and produces a JSON passport without uploading the source. The separate token candidate is not required for evidence verification, and no public sale, exchange listing, or production deployment is authorized by this research artifact.

Verification Algorithm

Algorithm 1

Local Passport Verification

```
INPUT: passport P, local artifact A, time t, policy Q
1  require schema(P) and canonicalizationProfile(P)
2  require SHA256(A) = P.artifactHash
3  require verifySignature(P.proof, issuerKey(P))
4  require scopeAccepted(P.scope, P.limitations)
5  require independentReviewer(P) and conflictChecked(P)
6  require P.status = VALIDATED and t <= P.validUntil
7  require notRevoked(P) and notSuperseded(P)
8  require Q(P) = true; return ACCEPT
9  on any failed requirement: return REJECT with reason
```

The verifier is fail-closed: malformed records, unknown algorithms, absent commitments, proof failures, unavailable status information, and policy failures produce rejection rather than a warning-only success state. The source implementation uses explicit custom errors and emits lifecycle events for auditability.

Reproducibility Package

The reproducibility package records the source revision, dependency lock file, test output, evaluation script, raw JSON results, machine environment, and document checksum. The public research artifact is available at https://github.com/SriMurukutla/sampling-sigma-evidence-passports. The evaluated submission snapshot is anchored by commit 3df129504776c6313f0b4a03ec0f242caa88a94d; a separate archival DOI may be added after depositing the tagged release in a long-term repository.

Measured Prototype Results

Experimental Setup

Study SS-DSR-PROTOTYPE-2026-10-29 executed three deterministic experiments and the repository contract suite. The mutation experiment generated 5,000 seeded byte strings, flipped one indexed bit in each string, and compared SHA-256 digests. The lifecycle reference model enumerated all 25 ordered pairs over Submitted, Validated, Rejected, Revoked, and

Superseded. The performance test hashed a deterministic one-mebibyte payload 256 times using a monotonic nanosecond timer. Contract tests ran through the repository's npm test command.

Observed Results

Table 4

Observed Prototype Measurements

Experiment	Observed result	Boundary
Contract suite	15 passing; exit 0	Not an audit
Mutation corpus	5000/5000 detected	Byte changes only
Lifecycle model	25 pairs; 21 forbidden rejected	Reference model
SHA-256 benchmark	Median 2.1396 ms; p95 2.7037 ms	Single machine/run

The controlled corpus detected 100% of 5,000 injected single-bit mutations. Under a simplifying independent-Bernoulli model, the exact two-sided 95% lower confidence bound for detection in this generator is 99.9263%.

$$L95 = 0.025^{(1/5000)} = 0.999263 \quad (3)$$

The bound describes only this seeded mutation generator; it does not estimate SHA-256 collision resistance, validate semantic truth, or establish an operational false-acceptance probability. The benchmark used Python 3.12.14 on macOS-15.4.1-x86_64-i386-64bit and measured 449.01 MiB/s for 256 one-mebibyte payloads. The latency distribution is reported by median and p95 because no normality assumption was made.

Table 5

Contract Suite Composition

Component	Tests	Primary behaviors
Assurance core	4	Commitments, independent review, supersession

Research core	6	Evidence validation, authorization, immutability
Token candidate	5	Fixed allocation, role separation, pause controls

All 15 repository tests passed in the recorded run. Four directly exercise the assurance core; six exercise research-record governance; five exercise the separate token candidate. Token tests are reported for repository completeness and do not constitute evidence for the assurance research questions. No independent audit, user study, interoperability test, production-availability study, or legal evaluation has been completed.

Comparative Evaluation Protocol

A controlled study will compare four conditions: raw digest exchange; a signed centralized JSON record; a W3C Verifiable Credential passport without a ledger; and Sampling Sigma with an optional shared registry. Participants will issue and verify identical evidence packages containing altered, expired, superseded, conflicted, and out-of-scope cases. An exploratory pilot of 24 to 30 participants will test the instruments and estimate variance. A confirmatory sample will then be determined by preregistered power analysis using a declared smallest effect of interest.

Table 6

Planned Primary Outcomes and Analysis

Outcome	**Definition**	**Analysis**
Accuracy	Correct accept/reject decision	Mixed logistic model
Time	Seconds to defensible decision	Survival/log-normal model
Critical error	Invalid accepted or valid rejected	Risk difference and CI
Completeness	Required context interpreted	Rubric and agreement
Privacy	Evidence bytes transmitted	Network capture
Usability	SUS and task workload	CI and effect size

The confirmatory protocol will fix primary outcomes, exclusions, and analysis before data collection. Holm correction will control multiplicity. Effect sizes and 95% confidence intervals will accompany p-values. Missing data, deviations, adverse events, and exclusions will be reported. Robust or nonparametric sensitivity analyses will address distributional violations.

Prospective Results and Decision Rules

This section contains prospective outcomes, not observed findings. The shared registry is justified only if it provides a measured advantage over simpler designs.

- If the lower 95% confidence limit for decision-accuracy improvement is above zero without increased critical errors, proceed to a larger pilot.
- If the credential-only passport is within the preregistered equivalence margin, prefer that simpler architecture.
- If users over-trust successful digest checks and the critical misconception rate exceeds 5%, redesign the verifier language and workflow.
- If reviewer independence cannot be verified, do not claim independent-review assurance.
- If metadata-correlation risk exceeds the approved privacy threshold, remove or reduce public metadata.

Validity Ethics and Reproducibility

Validity

Construct validity is protected by distinguishing digest equality from truth. Internal validity uses identical task packages, randomized order, logged deviations, and blinded scoring where practical. External validity is limited: results from a controlled pilot will not be generalized to all sectors or jurisdictions.

Ethics and Privacy

No real customer secrets or personal data will enter a public registry. Human-participant research requires the applicable institutional determination, informed consent where required, minimization, retention limits, and a withdrawal process. Security findings will follow coordinated disclosure.

Reproducibility

The release will include schemas, fixtures, source code, dependency versions, raw measurements, test output, analysis scripts, and replication instructions where legally permitted. IEEE's Code Ocean and DataPort integrations provide possible archival channels (IEEE Access, n.d.).

Governance and Economic Separation

The assurance protocol can operate without a tradable token. Any token distribution, sale, custody, listing, compensation, staking, or investment-oriented communication requires separate legal, tax, sanctions, consumer-protection, and securities analysis. Evidence validity must never depend on token ownership, price, or voting power. The article evaluates assurance architecture and does not make an investment claim.

Limitations

- The measurements are local prototype results and have not been independently replicated.
- The lifecycle experiment checks a reference model and is not a formal contract-equivalence proof.
- Identity, reviewer competence, organizational independence, and conflicts require external validation.

- No field evidence yet establishes decision improvement, usability, interoperability, or economic value.
- Public registries can introduce permanence, cost, governance, and metadata-correlation risks.

Conclusion

Sampling Sigma separates artifact integrity, decision context, independent review, lifecycle state, and optional economics. The prototype behaved consistently under the reported tests, but publication-strength claims about usefulness require the planned comparative study. The architecture should be retained only if it outperforms simpler alternatives on decision quality, privacy, continuity, or cross-organization coordination.

Acknowledgments

The author used OpenAI ChatGPT (OpenAI, 2026a) and Codex (OpenAI, 2026b) to assist with editorial restructuring, software development, generation of the reproducible evaluation harness, and document formatting in the Abstract, Sections I-XIII, and Appendix A. The author reviewed and verified the resulting text, code, citations, experiments, and submission statements. No artificial-intelligence output is treated as empirical evidence without independent execution and review.

Data Availability

The prototype source, dependency lock file, complete contract tests, evaluation script, raw JSON measurements, test transcript, checksum manifest, and submission-candidate manuscript are publicly available at https://github.com/SriMurukutla/sampling-sigma-evidence-passports. The paper's evaluated snapshot is commit

3df129504776c6313f0b4a03ec0f242caa88a94d. The repository is public under the MIT License for code; no independent audit, production approval, or regulatory determination is implied.

Appendix A Reproducibility Artifacts

Table 7

Reproducibility Artifacts

Artifact	Purpose
contracts/SamplingSigmaAssuranceCore.sol	Assurance record and lifecycle implementation
test/SamplingSigmaAssuranceCore.ts	Assurance-core behavioral tests
tools/research_evaluation.py	Mutation, lifecycle, benchmark, and test harness
evaluation/actual-prototype-results.json	Machine-readable observed measurements
evaluation/hardhat-test-output.txt	Recorded contract-test output

Minimum replication sequence: install the locked dependencies; run npm test; run python tools/research_evaluation.py; compare the resulting JSON study identifier, environment, test exit code, case counts, and timing statistics with the reported artifact. Timing values are expected to vary by machine; logical counts and rejection outcomes should not.

References

Coalition for Content Provenance and Authenticity. (n.d.). Content credentials technical specification. https://spec.c2pa.org/specifications/

Haber, S., & Stornetta, W. S. (1991). How to time-stamp a digital document. Journal of Cryptology, 3, 99–111. https://doi.org/10.1007/BF00196791

Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. MIS Quarterly, 28(1), 75–105. https://doi.org/10.2307/25148625

IEEE Access. (n.d.). Preparing your article. https://ieeeaccess.ieee.org/authors/preparing-your-article/

National Institute of Standards and Technology. (2015). Secure hash standard (FIPS PUB 180-4). U.S. Department of Commerce. https://doi.org/10.6028/NIST.FIPS.180-4

National Institute of Standards and Technology. (2022a). Assessing security and privacy controls in information systems and organizations (NIST SP 800-53A Rev. 5). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-53Ar5

National Institute of Standards and Technology. (2022b). Secure software development framework (SSDF) version 1.1 (NIST SP 800-218). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-218

OpenAI. (2026a). ChatGPT [Large language model]. https://chatgpt.com/

OpenAI. (2026b). Codex [AI coding agent]. https://openai.com/codex/

OpenZeppelin. (n.d.). OpenZeppelin contracts documentation. https://docs.openzeppelin.com/contracts/

Rundgren, A., Jordan, B., & Erdtman, S. (2020). JSON canonicalization scheme (JCS) (RFC 8785). Internet Engineering Task Force. https://doi.org/10.17487/RFC8785

Supply-chain Levels for Software Artifacts. (n.d.). SLSA specification version 1.2. https://slsa.dev/spec/v1.2/

Torres-Arias, S., Afzali, H., Kuppusamy, T. K., Curtmola, R., & Cappos, J. (2019). in-toto: Providing farm-to-table guarantees for bits and bytes. In 28th USENIX Security Symposium (USENIX Security 19) (pp. 1393–1410). USENIX Association. https://www.usenix.org/conference/usenixsecurity19/presentation/torres-arias

World Wide Web Consortium. (2025). Verifiable credentials data model v2.0. https://www.w3.org/TR/vc-data-model-2.0/